Projektarbeit IHK Cyber Security Advisor





Richtlinie für den sicheren administrativen Fernzugriff

zur Erlangung der Zertifizierung

IHK Cyber Security Advisor

Vorgelegt von Christian Petri
eingereicht am 14.12.2025
Kurs WBCS 11

Inhaltsverzeichnis

1. ProHost IT-Services GmbH 1
1.1. Vorstellung des Unternehmens 1
1.2. IT-Infrastruktur 1
2. Schutzbedarfsstruktur 2
3. SOLL-/IST-Abgleich 3
4. Risikoanalyse 4
5. Fazit 5

1. ProHost IT-Services GmbH

1.1. Vorstellung des Unternehmens

Die ProHost IT-Services GmbH ist ein spezialisierter Managed-Hosting-Provider, der hochverfügbare Linux-Server Umgebungen für mittelständische Kunden bereitstellt. Der technische Fokus liegt auf virtualisierten Infrastrukturen auf Basis von Proxmox VE und Container-Lösungen (LXC/Docker).

Mit rund 50 Mitarbeitenden, davon 35 im technischen Bereich, betreut das Unternehmen kritische Geschäftsanwendungen. Aufgrund der Unternehmensstruktur arbeiten die Administratoren überwiegend mobil oder aus dem Homeoffice. Bislang existieren jedoch keine verbindlichen Sicherheitsvorgaben für den administrativen Fernzugriff auf die Kunden-Infrastruktur.

Dieses Fehlen klarer Regelungen stellt ein erhebliches Sicherheitsrisiko dar, insbesondere im Hinblick auf Datenabfluss oder die Kompromittierung von Zugängen durch unsichere Netzwerke. Ziel dieser Arbeit ist daher die Entwicklung einer Richtlinie für den sicheren administrativen Fernzugriff gemäß **ISO 27001** und BSI IT-Grundschutz, um die Vertraulichkeit und Integrität der Kundensysteme zu gewährleisten.

1.2. IT-Infrastruktur

Zur Bewertung des Schutzbedarfs wird die Infrastruktur in sensible und nicht-sensible Bereiche unterteilt. Sensible Bereiche (Fokus Fernzugriff):

- **Proxmox-Cluster (Hypervisor):** Die physischen Server, auf denen sämtliche Kunden-VMs und Container laufen. Ein unbefugter Zugriff hierauf ermöglicht die vollständige Kontrolle über alle gehosteten Daten.
- **VPN-Gateways (OPNsense):** Der zentrale Eintrittspunkt in das Management-Netzwerk. Die Konfiguration und die Zugangsdaten (Zertifikate) sind kritisch.
- **SSH-Schlüsselverwaltung:** Private SSH-Keys dienen als primäres Authentifizierungsmittel für Linux-Server. Der Besitz dieser Keys gewährt oft direkten Root-Zugriff ohne weitere Passworteingabe.
- **Administrative Endgeräte (Laptops):** Diese Geräte werden mobil genutzt und enthalten temporäre Zugangsdaten, SSH-Keys und VPN-Konfigurationen. Sie unterliegen einem sehr hohen Schutzbedarf (Diebstahlrisiko).

Diese Bereiche erfordern zwingend Maßnahmen wie Verschlüsselung, 2-Faktor Authentifizierung (2FA) und VPN-Pflicht.

Nicht-sensible Bereiche:

- **Gast-WLAN:** Ein vom internen Netz isoliertes Netzwerk für Besucher, das keinen Zugriff auf Management-Schnittstellen erlaubt.
- **Öffentliche Webseite:** Der Webserver für die Firmenpräsentation enthält lediglich öffentliche Marketing-Informationen ohne Kundendaten.

Diese Bereiche erfordern lediglich Standardschutzmaßnahmen.

2. Schutzbedarfsstruktur

Asset / Wert	Speicherort / Typ	Schutzbedarf	Begründung
Kundendatenbanken	**SQL-Cluster (LXC/Docker)**	Sehr hoch	Diese Datenbanken enthalten sensible personenbezogene Daten und Geschäftsgeheimnisse der Kunden. Ein Vertraulichkeitsverlust würde zu massiven Reputationsschäden und hohen Bußgeldern führen.
Private SSH-Schlüssel	**Admin-Laptops / YubiKeys**	Sehr hoch	SSH-Keys gewähren direkten administrativen Zugriff (oft Root-Rechte) auf Kundensysteme. Ein Diebstahl dieser Schlüssel käme einer vollständigen Kompromittierung der Infrastruktur gleich.
Proxmox-Cluster	**Rechenzentrum (Server)**	Hoch	Die physische Basis (Hypervisor) für alle Kunden-VMs. Ein Ausfall oder eine Fehlkonfiguration beeinträchtigt die Verfügbarkeit aller gehosteten Dienste unmittelbar.
VPN-Konfiguration	**OPNsense Firewall**	Hoch	Das VPN-Gateway ist der zentrale Zugangspunkt für Administratoren. Eine Kompromittierung würde Angreifern den direkten Zugang zum internen Management-Netzwerk ermöglichen.
Admin-Notebooks	**Mobile Endgeräte**	Hoch	Da diese Geräte für den Fernzugriff genutzt werden, speichern sie temporär sensible Daten und Zugänge. Durch die mobile Nutzung besteht ein erhöhtes Risiko für Diebstahl oder Verlust.

3. SOLL-/IST-Abgleich

Hauptpflichten	SOLL	IST	Status	Verantwortlicher	Zeitraum
1.0 Verbindungssicherheit (VPN)	4	2	**Teilweise erfüllt**: Ein VPN-Gateway (WireGuard) ist grundsätzlich vorhanden und funktionsfähig. **Abweichung**: Kritische Management-Ports (SSH-Port 22, Proxmox Port 8006) sind noch teilweise direkt aus dem Internet erreichbar, um Admins den Zugriff zu erleichtern. Firewall-Regeln sind zu permissiv.	**Network Admin**	**Sofort**
2.0 Authentifizierung (MFA)	4	1	**Nicht erfüllt**: Die Authentifizierung erfolgt überwiegend nur klassisch mit Benutzername und Passwort. **Abweichung**: Eine 2-Faktor-Authentifizierung (MFA/TOTP) ist zwar systemseitig möglich, aber für VPN und Proxmox-Logins noch nicht zwangsweise aktiviert.	**IT-Leitung**	**1 Monat**
3.0 Endgerätesicherheit (Encryption)	4	2	**Teilweise erfüllt**: Es gibt Laptops mit Verschlüsselung, dies ist jedoch dem Anwender überlassen. **Abweichung**: Bei ca. 40 % der administrativen Endgeräte ist keine Full-Disk-Encryption (BitLocker/LUKS) aktiv oder der Status ist unbekannt (fehlendes MDM).	**IT-Support**	**2 Monate**
4.0 SSH-Sicherheit	4	2	**Teilweise erfüllt**: SSH-Keys kommen zum Einsatz, Standard ist jedoch nicht definiert. **Abweichung**: Auf älteren Kundensystemen ist der Root-Login via Passwort noch erlaubt (PermitRootLogin yes). Private Keys werden oft ohne Passphrase gespeichert.	**SysAdmins**	**2 Wochen**
5.0 Schulung der Mitarbeiter	4	3	**Teilweise erfüllt**: Es finden allgemeine Onboardings statt. **Abweichung**: Es findet keine spezifische, jährliche Unterweisung zu den Gefahren des mobilen Arbeitens (Public WiFi, Phishing, Umgang mit YubiKeys).	**IT-Leitung / HR**	**Regelmäßig (1x Jährlich)**

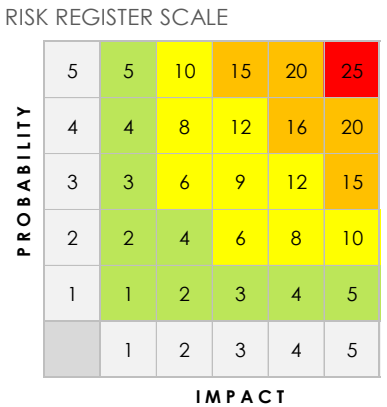
Legende:

- **(1) Kritisch:** Akutes Sicherheitsrisiko, sofortiger Handlungsbedarf.
- **(2) Mangelhaft:** Anforderungen nicht erfüllt, erhebliche Lücken.
- **(3) Ausreichend:** Grundschutz vorhanden, Verbesserungen nötig.
- **(4) Erfüllt:** Entspricht den Anforderungen vollständig.

4. Risikoanalyse

Risk ID	Beschreibung Schwachstellen	Beschreibung Auswirkungen	Maßnahme & Risk-Owner	(A)	(W)	(R)
R-001	**Unverschlüsselte Endgeräte** Laptops werden mobil genutzt, verfügen aber nicht über eine aktive Festplattenverschlüsselung (BitLocker/LUKS).	**Verlust von SSH-Keys** und Zugangsdaten bei Diebstahl Angreifer erhalten Root-Zugriff	**SOLL-/IST Punkt 3.0** (IT-Support)	**5**	**3**	**15**
R-002	**Fehlende MFA** Admins nutzen für VPN oder Proxmox-Login nur einfache Passwörter.	Erhöhtes Risiko von **Identitätsdiebstahl** und unbefugtem Zutritt.	**SOLL-/IST Punkt 2.0** (IT-Leitung)	**4**	**4**	**16**
R-003	**Unsichere Verbindung** Direkter Zugriff auf SSH/Proxmox ohne VPN aus öffentlichen WLANs möglich.	**Man-in-the-Middle-Angriffe** (Abfangen von Session-Cookies oder Passwörtern)	**SOLL-/IST Punkt 1.0** (Network-Admin)	**3**	**3**	**9**
R-004	**Veraltete SSH-Config** Root-Login mit Passwort auf einigen Servern noch erlaubt.	**Brute-Force-Angriffe** auf das Root-Passwort können erfolgreich sein.	**SOLL-/IST Punkt 4.0** (Sys-Admin)	**5**	**2**	**10**
R-005	**Fehlende Sensibilisierung** Mitarbeiter sind nicht spezifisch auf Gefahren des mobilen Arbeitens (Public WiFi, Shoulder Surfing) geschult	**Erfolgreiches Social Engineering** Erhöhte Wahrscheinlichkeit, dass Phishing-Mails (z.B. VPN-Login Fake) Erfolg haben	**SOLL-/IST Punkt 5.0** (IT-Leitung/HR)	**4**	**3**	**12**

Legende:
A= Auswirkung
W= Wahrscheinlichkeit
R= Risiko



5. Fazit

Die Risikoanalyse zeigt, dass der aktuelle Zustand des administrativen Fernzugriffs untragbare Risiken (Score 15 & 16) birgt. Insbesondere die Kombination aus fehlender Verschlüsselung auf Endgeräten und fehlender 2-Faktor-Authentifizierung macht die Infrastruktur verwundbar gegenüber Standardangriffen. Die in der nachfolgenden Richtlinie definierten Maßnahmen sind daher zwingend erforderlich, um das Risikoniveau auf ein akzeptables Maß zu senken.

Richtlinie für den sicheren administrativen Fernzugriff

Eigenschaft	Beschreibung
Titel	Fernzugriffsrichtlinie
Dokumentebene	Operative Richtlinie
Management Kategorie	IT-Sicherheit
Sicherheitsklassifizierung	SK-1 (Intern)
Referenz Dokumente	ISO/IEC 27001:2022 (A.8.20), BSI IT-Grundschutz (OPS.1.1.2, OPS.1.2.5)
Hauptverantwortlicher	Max Mustermann / IT-Leiter & CEO
Ansprechpartner	Christian Petri / ISB
E-Mail, Telefon	c.petri@prohost-services.de / +49 123 456789
Autor	Christian Petri
In Kraft seit	14.12.2025
In Kraft gesetzt durch	Max Mustermann / CEO
Überarbeitungsintervall	12 Monate
Nächste Überarbeitung	14.12.2026

Dokumenteneigenschaften			
Version	Änderung	Datum	Autor
v.1.0	Initialerstellung	09.12.2025	Christian Petri
v.1.0.1	Multifaktorauthentifizierung	09.12.2025	Christian Petri
v.1.1	Finale Version	14.12.2025	Christian Petri

Inhaltsverzeichnis:

1. Geltungsbereich 1
2. Zweck 1
3. Verantwortlichkeiten 1
4. Regelungen und Maßnahmen 2
4.1. Verbindungssicherheit und VPN-Pflicht 2
4.2. Authentifizierung und SSH-Sicherheit 2
4.3. Sicherheit der Endgeräte 2
5. Pflichten von Systembetreibern (Infrastruktur) 3
5.1. Accountsperrung und Brute-Force-Schutz 3
5.2. Multifaktorauthentifizierung (Systemseitig) 3
6. Schulung der Mitarbeiter 4
7. Genehmigung von Ausnahmen 4
8. Berichterstattung und Eskalation 4
9. Gültigkeit, Verwaltung und Überprüfung 4
10. Konsequenz bei Nichteinhaltung 5

1. Geltungsbereich

Diese Richtlinie gilt für sämtliche Beschäftigte, Auftragnehmer und sonstige Dienstleister der ProHost IT-Services GmbH, die über öffentliche Netzwerke (Fernzugriff) Zugang zu administrativen IT-Systemen, Kundendatenbanken oder der Management-Infrastruktur (z. B. Proxmox, SSH) erhalten.

2. Zweck

Der Zweck dieser Richtlinie ist die Gewährleistung eines sicheren IT-Betriebs bei administrativen Tätigkeiten außerhalb des geschützten Firmennetzwerks. Da Fernzugriffe über potenziell unsichere Übertragungswege (Internet) erfolgen, definiert dieses Dokument verbindliche Sicherheitsvorgaben für die Authentifizierung, Geräteverschlüsselung und Verbindungssicherheit (VPN). Ziel ist es, unbefugte Zugriffe, Datenabfluss und Manipulationen an Kundensystemen effektiv zu verhindern.

3. Verantwortlichkeiten

- **IT-Sicherheitsbeauftragter (ISB):** Entwickelt die Vorgaben für den sicheren Fernzugriff und passt diese an die aktuelle Bedrohungslage an. Überwacht die Einhaltung der Richtlinie durch regelmäßige Audits (z. B. Prüfung der VPN-Logs) und ist Ansprechpartner bei Sicherheitsfragen.
- **Systemadministratoren:** Sind verantwortlich für die technische Umsetzung der Fernzugriffs-Infrastruktur. Dies umfasst die Konfiguration der VPN-Gateways, die Verwaltung der SSH-Schlüssel und die Erzwingung der Multifaktorauthentifizierung (MFA). Sie stellen sicher, dass nur autorisierte Endgeräte Zugriff erhalten.
- **IT-Mitarbeiter:** Unterstützen bei der Einrichtung sicherer Arbeitsplätze und melden technische Probleme oder Sicherheitslücken im Fernzugriff umgehend an die IT-Leitung.
- **HR-Manager:** Verantwortlich für den Prozess bei Ein- und Austritt von Mitarbeitern (On-/Offboarding). Stellt sicher, dass Zugriffs-Token (z. B. YubiKeys) bei Austritt sofort zurückgefordert und Zugänge gesperrt werden. Organisiert Sensibilisierungsmaßnahmen zum Thema „Sicheres mobiles Arbeiten“.
- **IT-Abteilungsleiter:** Tragen die Verantwortung dafür, dass ihre Teams ausschließlich die genehmigten Fernzugriffswege nutzen. Sie genehmigen Ausnahmen nur in schriftlicher Abstimmung mit dem ISB.
- **Mitarbeiter:** Sind verpflichtet, die Sicherheitsvorgaben dieser Richtlinie strikt einzuhalten (z. B. Nutzung von VPN, Schutz vor Einsichtnahme Dritter) und den Verlust von Arbeitsmitteln (Laptop, Token) unverzüglich zu melden.

4. Regelungen und Maßnahmen

4.1. Verbindungssicherheit und VPN-Pflicht

Der Zugriff auf interne Managementschnittstellen (z. B. Proxmox-GUI, Datenbanken, interne Wikis) sowie administrative SSH-Zugänge ist aus öffentlichen Netzwerken (Internet) generell untersagt.

1. **VPN-Nutzung:** Jeglicher administrative Zugriff muss über einen verschlüsselten VPN-Tunnel (z. B. WireGuard oder OpenVPN) erfolgen. Der direkte Zugriff auf Management-Ports (Port 22, 8006) über das öffentliche Internet ist durch Firewall-Regeln zu blockieren.
2. **Öffentliche Netzwerke:** Bei der Arbeit in ungesicherten Netzwerken (z. B. Hotel-WLAN, Hotspots) ist der VPN-Tunnel vor jeglicher arbeitsbezogenen Tätigkeit aufzubauen, um das Abhören von Verbindungsdaten (Man-in-the-Middle-Angriffe) zu verhindern.

4.2. Authentifizierung und SSH-Sicherheit

Um Identitätsdiebstahl und unbefugte Zugriffe zu verhindern, gelten für die Authentifizierung folgende Vorgaben:

1. **Multifaktorauthentifizierung (MFA):** Für den Aufbau der VPN-Verbindung sowie für den Login an Web-Interfaces (Proxmox, Firewall) ist zwingend ein zweiter Faktor zu nutzen (z. B. TOTP-App oder YubiKey).
2. **SSH-Zugang:**
    - Der Login via Passwort ist auf allen Linux-Servern zu deaktivieren (PasswordAuthentication no).
    - Es sind ausschließlich SSH-Schlüsselpaare (bevorzugt Ed25519 oder RSA ≥ 4096 Bit) zur Authentifizierung zu verwenden.
    - Der direkte Login als root ist verboten (PermitRootLogin no). Administrative Tätigkeiten sind über einen personalisierten Benutzer mittels sudo durchzuführen.
3. **Private Keys**: Private SSH-Schlüssel müssen durch eine starke Passphrase geschützt sein und dürfen niemals unverschlüsselt übertragen oder auf geteilten Netzlaufwerken gespeichert werden.

4.3. Sicherheit der Endgeräte

Da administrative Endgeräte (Laptops) sensible Zugangsdaten enthalten, unterliegen sie besonderen Schutzanforderungen:

1. **Festplattenverschlüsselung**: Alle mobilen Endgeräte müssen über eine aktive Full-Disk-Encryption (FDE) verfügen (z. B. LUKS für Linux, BitLocker für Windows). Der Systemstart darf erst nach erfolgreicher Eingabe eines Entschlüsselungspassworts erfolgen.
2. **Bildschirmsperre**: Bei Verlassen des Arbeitsplatzes – auch im Homeoffice – ist der Bildschirm sofort zu sperren. Die automatische Sperre ist auf maximal 5 Minuten Inaktivität einzustellen.

3. **Updates**: Das Betriebssystem und sicherheitskritische Anwendungen (Browser, VPN-Client) müssen stets auf dem aktuellen Stand gehalten werden (automatische Updates aktiviert).

5. Pflichten von Systembetreibern (Infrastruktur)

Die Systemadministratoren und Betreiber der Proxmox- und VPN-Infrastruktur sind verpflichtet, die Systeme so zu konfigurieren, dass sie den Sicherheitsvorgaben entsprechen.

1. **Verschlüsselte Übertragung**: Administrative Zugriffe (SSH, Web-GUI) dürfen ausschließlich über verschlüsselte Kanäle nach aktuellem Stand der Technik erfolgen (z. B. SSHv2, TLS 1.3 für Webinterfaces, WireGuard/IPsec für VPN). Veraltete Protokolle (Telnet, FTP, HTTP) sind serverseitig zu deaktivieren.
2. **Sichere Speicherung:** Die Datenbanken der Authentifizierungsserver (LDAP/Active Directory) und die shadow-Files der Linux-Server müssen gegen unbefugten Zugriff gesichert und die Passwörter darin mittels starker Hashing-Algorithmen (z. B. Argon2 oder SHA-512) gespeichert werden.

5.1. Accountsperrung und Brute-Force-Schutz

Um automatisierte Passwort-Rateversuche (Brute-Force) zu unterbinden, sind technische Maßnahmen auf Netzwerk- und Anwendungsebene zu implementieren:

1. **Login-Drosselung (Fail2Ban):** Auf allen öffentlich erreichbaren Schnittstellen (sofern VPN ausfällt) muss ein Mechanismus wie Fail2Ban oder CrowdSec aktiv sein. Nach maximal 5 fehlerhaften Anmeldeversuchen ist die Quell-IP-Adresse temporär für mindestens 10 Minuten zu sperren.
2. **Dauerhafte Sperre:** Bei Systemen im „Sensiblen Bereich“ (Root-Zugänge, VPN-Gateways) wird das Benutzerkonto nach 10 Fehlversuchen dauerhaft deaktiviert. Eine Reaktivierung ist nur manuell durch den IT-Sicherheitsbeauftragten nach Identitätsprüfung möglich.

5.2. Multifaktorauthentifizierung (Systemseitig)

Systeme der Kategorie „Sensibler Bereich“ (VPN, Proxmox-Cluster, Firewall-Admin) müssen so konfiguriert sein, dass eine Anmeldung ohne zweiten Faktor technisch unmöglich ist.

1. **Faktor-Anforderung:** Es ist sicherzustellen, dass die verwendeten Faktoren aus unterschiedlichen Kategorien stammen:
    - *Wissen:* Persönliches Passwort oder Passphrase des SSH-Keys.
    - *Besitz:* Hardware-Token (**YubiKey**), Smartcard oder TOTP-App.
2. **Durchsetzung:** Die Umgehung von MFA für administrative Accounts ist untersagt, es sei denn, es liegt ein dokumentierter Notfallplan (Break-Glass-Account) vor.

6. Schulung der Mitarbeiter

Alle Mitarbeiterinnen und Mitarbeiter der ProHost IT-Services GmbH, die über Fernzugriffe verfügen, sind verpflichtet, **einmal jährlich** eine Schulung zum Thema „Sicherer administrativer Fernzugriff“ zu absolvieren. Im Rahmen dieser Trainings werden Best Practices zur SSH-Key-Verwaltung, Erkennung von Phishing-Angriffen auf VPN-Zugangsdaten und die korrekte Nutzung von Multifaktor-Token vermittelt. Die Teilnahme ist zu dokumentieren. Der ISB übernimmt diese Schulung.

7. Genehmigung von Ausnahmen

Falls die Mindestanforderungen dieser Richtlinie aus technischen Gründen (z. B. Legacy-Systeme bei Kunden) nicht erfüllt werden können, kann in Absprache mit dem ISB eine befristete Ausnahmegenehmigung erteilt werden. Diese Ausnahme ist schriftlich zu begründen und im Risikoregister zu dokumentieren. Ausnahmeregelungen werden halbjährlich überprüft und widerrufen, sobald die technischen Gegebenheiten eine Absicherung erlauben.

8. Berichterstattung und Eskalation

Alle Mitarbeiter sind verpflichtet, potenzielle Verstöße gegen diese Richtlinie, verdächtige Netzwerkaktivitäten oder den Verlust von Zugangsdaten unverzüglich an den internen ISB zu melden.

- **Meldewege**: Die Meldung erfolgt über das interne Ticket-System (Priorität: Hoch) oder in dringenden Fällen (z. B. aktiver Angriff, Verlust des Laptops) direkt per Telefon.
- **Reaktion**: Falls der Verdacht besteht, dass ein SSH-Key oder VPN-Zugang kompromittiert wurde, muss dieser unverzüglich gesperrt und ausgetauscht werden („Key Rollover“).

9. Gültigkeit, Verwaltung und Überprüfung

Diese Richtlinie tritt mit Wirkung zum 14.12.2025 in Kraft. Der interne ISB ist als Eigentümer des Dokuments für dessen Pflege verantwortlich.

Es ist erforderlich, mindestens zweimal jährlich Audits durchzuführen, um die Einhaltung der Fernzugriffsrichtlinie zu überprüfen. Zu den verpflichtenden Prüfkriterien zählen:

- Überprüfung der Firewall- und VPN-Logs auf Anomalien.
- Audit der berechtigten SSH-Keys auf den Servern (Entfernung alter Keys).
- Abgleich der aktiven Benutzerkonten mit der Personalliste (HR).
- Änderungen an **ISO 27001** oder BSI IT-Grundschutz (Baustein **OPS.1.1.2/OPS.1.2.5**).

Die Ergebnisse der Audits werden dokumentiert. Auf Basis dieser Analysen erstellt der ISB einen Maßnahmenplan zur kontinuierlichen Verbesserung der Infrastruktursicherheit. Um eine lückenlose Information sicherzustellen, wird die Richtlinie per E-Mail an alle technischen Mitarbeiter versendet und dauerhaft im Firmen-Intranet/Wiki an prominenter Stelle veröffentlicht.

Kennzahl	Messung	Methode	Intervall	Verantwortlichkeit	Interpretation
Verschlüsselungs-Quote	Anteil der administrativen Laptops mit aktiver Full-Disk-Encryption (BitLocker/LUKS).	Stichprobenartige Prüfung oder Report aus dem Asset-Management.	Quartalsweise	IT-Support	Ein Wert unter 100 % stellt ein kritisches Sicherheitsrisiko bei Geräteverlust dar.
MFA-Abdeckung	Anzahl der administrativen Accounts (VPN, Proxmox) ohne aktiven zweiten Faktor.	Audit der Benutzerdatenbanken und VPN-Konfigurationen.	Monatlich	System-Administration	Zielwert ist 0. Jeder Account ohne MFA ist ein potenzielles Einfallstor für Angreifer.
Schulungs-Teilnahme	Prozentsatz der technischen Mitarbeiter, die die jährliche Unterweisung absolviert haben.	Abgleich der Teilnehmerlisten mit der Personalliste (HR).	Jährlich	HR / IT-Leitung	Eine hohe Quote (>95 %) korreliert mit gesunkenem Risiko für erfolgreiches Social Engineering.
SSH-Härtung	Anzahl der Server, die noch Root-Login oder Passwort-Auth erlauben.	Automatisierter Scan der SSH-Konfigurationen (Skript).	Halbjährlich	IT-Sicherheitsbeauftragter (ISB)	Das Vorhandensein unsicherer Konfigurationen deutet auf Prozesslücken im Deployment hin.

10. Konsequenz bei Nichteinhaltung

Die Nichteinhaltung dieser Richtlinie stellt eine Verletzung der arbeitsvertraglichen Pflichten und der Sicherheitsvorgaben der ProHost IT-Services GmbH dar. Verstöße können je nach Schweregrad zu disziplinarischen Maßnahmen führen, die von einer Abmahnung bis hin zur Beendigung des Arbeitsverhältnisses reichen. Zudem wird bei Verstößen der administrative Fernzugriff sofortig entzogen.

Darmstadt, den 14.12.2025

X	X
Christian Petri	Max Mustermann
ISB	CEO